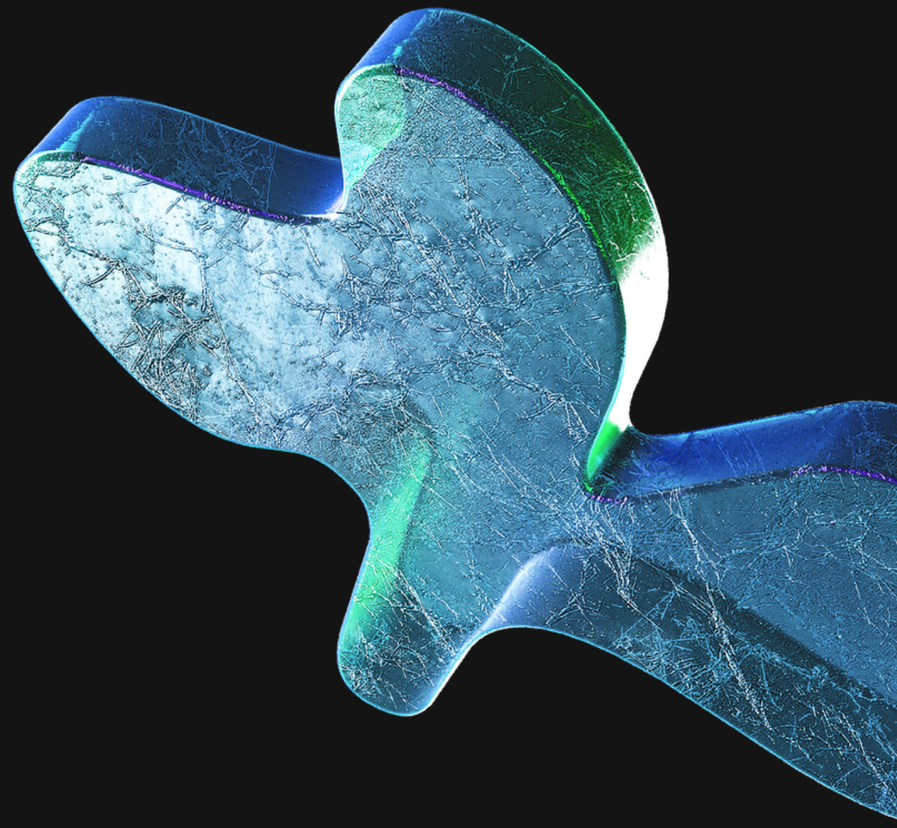
SEMINÁRIO ATAQUES

DDOS

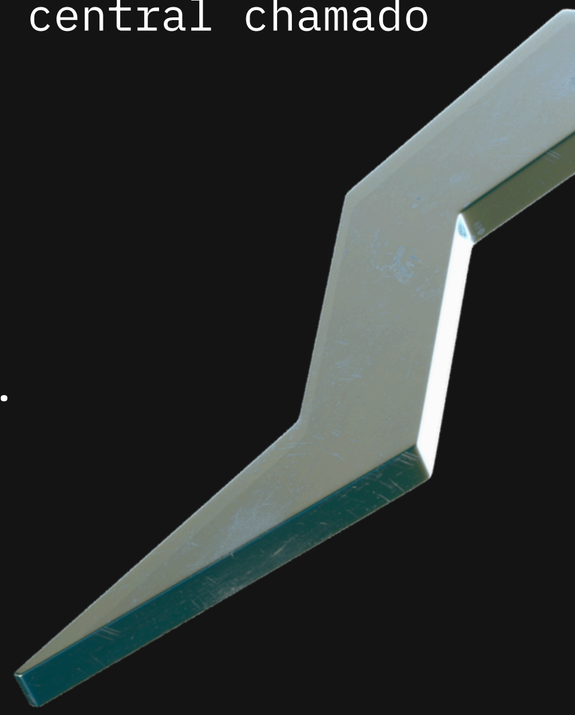
DISTRIBUTED DENIAL OF SERVICE



Tiago, Kaique, Mateus, Lucas Estevam.

EXPLICAÇÃO TÉCNICA

- Infecção de dispositivos (Botnet)
- O atacante infecta diversos dispositivos (PCs, celulares, IoT) com malware.
- Esses dispositivos passam a ser chamados de bots ou zumbis.
- Formação da Botnet
- Todos os dispositivos infectados ficam sob controle de um servidor central chamado C2 (Command and Control).
- Escolha do alvo
- Pode ser um site, servidor, API, jogo online ou sistema bancário.
- Disparo do ataque
- O atacante envia um comando via C2.
- Todos os bots começam a enviar requisições simultaneamente ao alvo.
- Sobrecarga do servidor
- O servidor tenta responder a todas as requisições.
- Consome CPU, memória, banda de rede.
- Indisponibilidade
- O serviço fica lento ou cai completamente.



PROTOCOLOS E CAMADAS

Os ataques DDoS exploram diversos protocolos da internet:

Camada de Rede (L3)

- IP (Internet Protocol) → base de toda comunicação
- ICMP (Ping Flood) → usado para sobrecarregar

Camada de Transporte (L4)

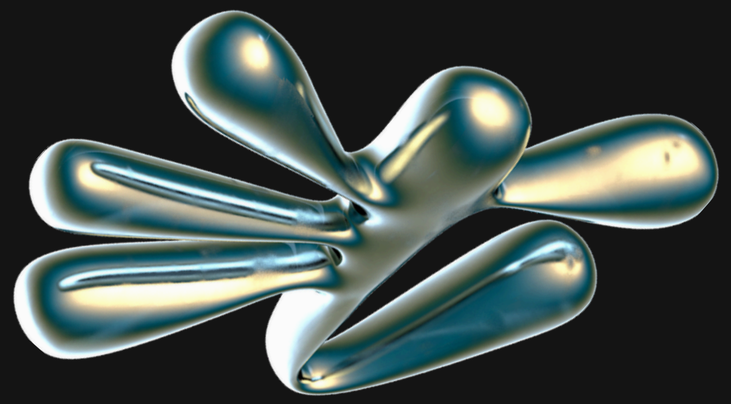
- TCP
- SYN Flood (explora o handshake TCP)
- UDP
- UDP Flood (envio massivo sem conexão)

Camada de Aplicação (L7)

- HTTP/HTTPS
- HTTP Flood (simula acessos reais)
- DNS
- Amplificação DNS (respostas maiores que requisições)

Camada	Nome	Como é afetada
7	Aplicação	HTTP Flood, DNS Flood
6	Apresentação	Criptografia (HTTPS sobrecarrega CPU)
5	Sessão	Excesso de conexões simultâneas
4	Transporte	SYN Flood, UDP Flood
3	Rede	ICMP Flood, spoofing de IP
2	Enlace	Pode ser afetada indiretamente
1	Física	Saturação de banda

FERRAMENTAS ULTILIZADAS



Principais Ferramentas (Categorias):

- Camada de Rede (Inundação): Ferramentas como UDP Flood ou ICMP Flood tentam esgotar a largura de banda da "estrada" que leva ao servidor.

- Camada de Aplicação (Exaustão de Recursos): Ferramentas como Slowloris e HULK são mais sutis; elas não tentam derrubar a internet do alvo, mas sim "travar" o software do servidor (como o Apache ou Nginx) fazendo-o processar requisições infinitas.

- Ferramentas de "Estresse": Softwares como LOIC e HOIC permitem que usuários comuns participem de ataques coordenados, enviando pacotes em massa.

O Mecanismo de Força:

- Botnets: O ataque raramente vem de um só computador. Ele utiliza uma rede de dispositivos infectados (Internet das Coisas, roteadores, PCs) que atacam simultaneamente sob o comando de um invasor.

- Amplificação: O invasor usa servidores públicos (como DNS) para enviar uma pergunta pequena que gera uma resposta gigante, direcionando todo esse volume para a vítima.

ARQUITETURA DO ATAQUE

1. O Atacante (Mestre): Define o alvo e o tipo de ataque (ex: inundação de pacotes ou exaustão de memória).

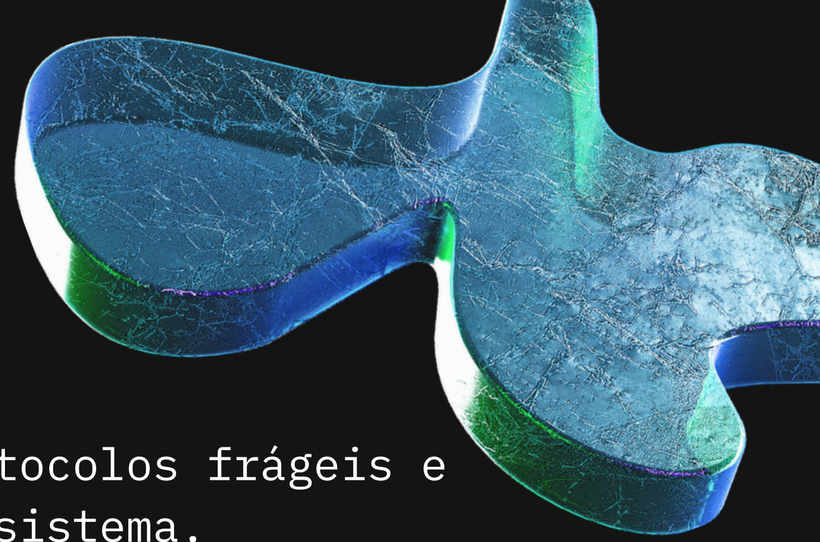
2. Servidor C&C (Comando e Controle): O atacante envia a ordem para um servidor central que gerencia os dispositivos infectados.

3. A Botnet (Exército): Milhares de dispositivos (PCs, câmeras de segurança, roteadores) recebem o comando e começam a enviar dados para o mesmo endereço IP ao mesmo tempo.

5. O Alvo (Vítima): O servidor do site recebe tanto tráfego que não consegue mais distinguir o que é um acesso real de um acesso falso.

6. Resultado: O sistema trava ou fica tão lento que usuários legítimos são "negados" (Denial of Service).

O QUE CAUSA O ATAQUE



- Vulnerabilidades exploradas: servidores sem proteção, protocolos frágeis e ausência de limite de requisições permitem sobrecarga do sistema.

- Falhas humanas ou técnicas: sistemas desatualizados, senhas fracas e falta de monitoramento facilitam ataques.

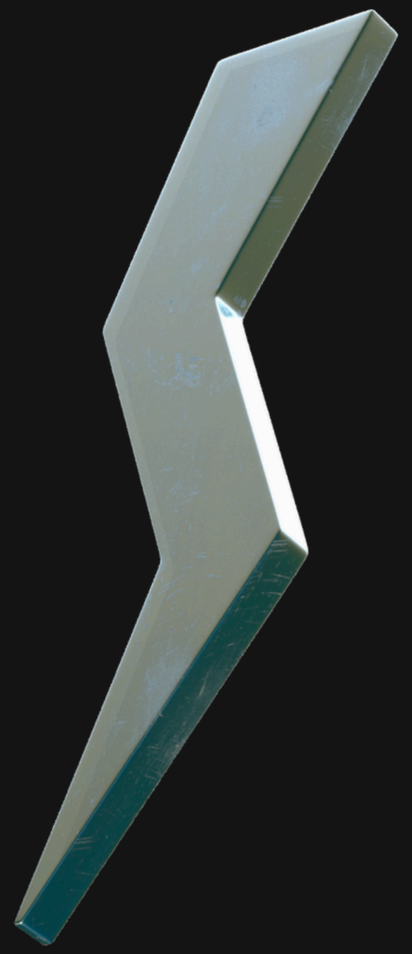
- Erros de configuração: serviços expostos, firewall mal configurado e falta de balanceamento de carga aumentam o risco.

- Engenharia social: invasores podem enganar usuários para obter acesso e criar redes de bots (botnets).

IMPACTOS TECNICOS

Principais consequências:

- Sobrecarga de servidores
  - CPU e memória ficam no limite
- Saturação de banda de rede
  - A internet fica lenta ou inutilizável
- Queda de sistemas
  - Sites, APIs e serviços param de funcionar
- Instabilidade geral
  - Travamentos, erros e falhas constantes
- Dificuldade de mitigação
  - Ataques modernos são distribuídos e difíceis de bloquear



IMPACTOS FINANCEIROS E OPERACIONAIS

- Perda de receita
- E-commerce fora do ar = vendas perdidas
- Custos com mitigação
- Serviços de proteção como Cloudflare ou AWS Shield
- Multas e penalidades
- Por não cumprir SLAs (acordos de serviço)
- Danos à reputação
- Clientes perdem confiança
- Custos de recuperação
- Equipe técnica, upgrades de infraestrutura

- Interrupção de operações
  - Sistemas internos param (ERP, CRM)
- Queda de produtividade
  - Funcionários não conseguem trabalhar
- Atendimento prejudicado
  - Call centers, apps e suporte ficam fora do ar
- Dependência de sistemas digitais
  - Hoje quase tudo depende da internet

VAZAMENTOS DE DADOS

- Interrupção de operações
  - Sistemas internos param (ERP, CRM)
- Queda de produtividade
  - Funcionários não conseguem trabalhar
- Atendimento prejudicado
  - Call centers, apps e suporte ficam fora do ar
- Dependência de sistemas digitais
  - Hoje quase tudo depende da internet

INDISPONIBILIDADE DE SERVIÇOS

Efeitos:

- Sites fora do ar
- Aplicativos indisponíveis
- Jogos online caem
- Serviços bancários inacessíveis

Resultado:

- Usuários não conseguem acessar o sistema
- Perda imediata de confiança
- Impacto direto no negócio

COMO SE PROTEGER

Após identificar um ataque DDoS, a resposta precisa ser rápida, organizada e estratégica para reduzir danos e restaurar os serviços.

O primeiro objetivo é parar ou reduzir o impacto do ataque.
Ações imediatas:

- Ativar proteção anti-DDoS
  - Serviços como Cloudflare ou AWS Shield
- Filtrar tráfego malicioso
  - Bloquear IPs suspeitos
  - Usar firewall e WAF (Web Application Firewall)
- Aplicar rate limiting
  - Limitar número de requisições por usuário/IP
- Redirecionar tráfego
  - Usar CDN para absorver o volume
- Blackhole (em último caso)
  - Bloquear totalmente o tráfego para proteger a rede interna

COMO SE PROTEGER

Isolamento de sistemas
Evita que o problema se espalhe ou cause mais danos.
O que fazer:

- Separar sistemas críticos
  - Isolar servidores essenciais
- Desconectar serviços vulneráveis
  - Temporariamente tirar do ar partes não essenciais
- Segmentar a rede
  - Evitar que o ataque afete toda a infraestrutura
- Verificar comprometimento
  - Garantir que não há invasão junto com o DDoS

Recuperação
Após conter o ataque, é hora de restaurar tudo com segurança.
Etapas:

- Restaurar serviços gradualmente
  - Evitar novo colapso
- Testar estabilidade
  - Verificar se o sistema aguenta o tráfego
- Atualizar sistemas
  - Corrigir vulnerabilidades exploradas
- Reforçar segurança
  - Configurar melhor firewall, CDN e monitoramento

COMO SE PROTEGER

Comunicação
Fundamental para manter confiança e organização.
Comunicação interna:

- Informar equipe técnica e gestores
- Coordenar ações rapidamente
-

Comunicação externa:

- Avisar usuários/clientes sobre instabilidade
- Ser transparente (sem expor falhas críticas)
- Atualizar status do serviço

PLANO DE RESPOSTAS

Após o ataque, é essencial melhorar a preparação futura.

O que incluir no plano:

- Documentação do incidente
  - O que aconteceu, como aconteceu
- Análise pós-incidente (post-mortem)
  - Identificar falhas
- Melhoria de processos
  - Corrigir erros humanos e técnicos
- Treinamento da equipe
  - Preparar para novos ataques
- Simulações futuras
  - Testar resposta a incidentes

COMO SE PROTEGER

Medidas preventivas

- Construa uma infraestrutura resiliente, utilizando CDNs para distribuir tráfego e esconder o IP real dos servidores, balanceadores de carga para distribuir requisições e rate limiting para controlar o número de requisições por IP. Isso ajuda a evitar sobrecargas e limita os impactos de ataques.

Ferramentas de mitigação

- Utilize serviços especializados como Cloudflare, AWS Shield ou Google Cloud Armor para bloquear ataques em tempo real. O WAF (Web Application Firewall) filtra requisições maliciosas, enquanto ferramentas de mitigação de bots ajudam a bloquear tráfego automatizado.

Configurações recomendadas

- Ajuste a configuração do servidor para limitar conexões simultâneas, controlar requisições e implementar proteções como SYN cookies. Além disso, configure o firewall para bloquear padrões anômalos e IPs suspeitos, reduzindo a superfície de ataque.

COMO SE PROTEGER

Monitoramento e detecção

- Monitore constantemente o tráfego, a latência e os erros com ferramentas como Prometheus e Grafana. Configure alertas para identificar picos de tráfego ou comportamentos anômalos, ajudando a detectar ataques logo no início.

Boas práticas de segurança

- Oculte o IP real do servidor e restrinja acessos a áreas sensíveis usando VPN ou whitelisting. Mantenha os sistemas atualizados e realize testes de carga regulares para identificar pontos fracos.

CASOS DE ATAQUES REAIS

ATAQUE AO GITHUB

Em fevereiro de 2018, a plataforma GitHub foi alvo de um dos maiores ataques DDoS registrados na época.

- O Ataque: A plataforma foi atingida por uma inundação de tráfego via Memcached (um sistema de cache de banco de dados) que atingiu um pico de 1,35 Tbps (terabits por segundo).
- Como foi feito: Os atacantes exploraram servidores memcached vulneráveis, amplificando o tráfego enviado ao GitHub sem precisar comprometer as máquinas diretamente.
- Desfecho: O GitHub utilizou serviços de mitigação (Cloudflare) e o ataque foi absorvido em cerca de 10 minutos, limitando o tempo de inatividade.

CONSEQUÊNCIAS

- Indisponibilidade Temporária: O site do GitHub ficou fora do ar ou enfrentou instabilidades severas por aproximadamente 10 a 20 minutos.

- Ataque de Memcached: Os atacantes utilizaram uma técnica inovadora explorando servidores Memcached vulneráveis (um sistema de cache de banco de dados), que amplificou o tráfego malicioso em dezenas de milhares de terminais únicos.

- Dados Protegidos: O GitHub informou rapidamente que os dados dos usuários não foram comprometidos.

- Mitigação Rápida: A plataforma utilizou serviços de proteção automatizados (como a Akamai) para identificar e bloquear o ataque, restabelecendo o serviço em pouco tempo.

- Reforço de Infraestrutura: Após o incidente, o GitHub relatou ter reforçado sua capacidade de rede e proteção contra ataques de negação de serviço.

FONTES:

CERT.br
https://www.cloudflare.com/learning/ddos/what-is-a-ddos-attack/
https://www.kaspersky.com/resource-center/threats/ddos-attacks
https://scholar.google.com